

BÁO CÁO KIỂM TOÁN HỆ THỐNG & CHẤT LƯỢNG MÃ NGUỒN

ĐÁNH GIÁ CHẤT LƯỢNG MÃ NGUỒN, BẢO MẬT & LƯUỒNG NGHIỆP VỤ E-COMMERCE

DỰ ÁN: T'PETIE (VERCEL PRODUCTION)
URL ĐỐI TƯỢNG: <https://t-petie.vercel.app/>
CHUẨN ĐỐI CHIẾU: ATINO.VN // BAYMARD // OWASP
NGƯỜI THỰC HIỆN: NGUYỄN MINH TOÀN
NGÀY THẨM ĐỊNH: 28/09/2026

■ CƠ SỞ KHOA HỌC & BỘ TIÊU CHUẨN THẨM ĐỊNH QUỐC TẾ ÁP DỤNG

VALIDATED SOURCES

- Baymard Institute (USA):** Tiêu chuẩn Usability E-Commerce dựa trên 130.000+ giờ kiểm thử hành vi thực tế về Cấu trúc Điều hướng, Hiển thị sản phẩm Above-the-fold & Lọc đa tầng (Faceted Filtering).
- Nielsen Norman Group (NN/g):** Khung lý thuyết Kiến trúc thông tin (IA) & Chi phí tương tác (Interaction Cost) trong thương mại điện tử.
- Google Retail UX Playbook:** Chuẩn tối ưu hóa hành trình mua sắm di động (Mobile-First Retail) và nguyên tắc loại bỏ ma sát đặt hàng.
- OWASP Top 10 (2021) & API Security Top 10 (2023):** Bộ chuẩn an ninh ứng dụng web & lỗ hổng Broken Access Control (A01), Insecure Design (A04).
- Dữ liệu đối chiếu thực tế (Local Benchmark):** Mô hình luồng nghiệp vụ chuẩn mực của **Atino.vn**, Routine, Coolmate.

KẾT LUẬN KIỂM TOÁN: KHÔNG ĐỦ ĐIỀU KIỆN TRIỂN KHAI PRODUCTION

SCORE: 0 / 100 [REJECTED]

Hệ thống tồn tại kiến trúc phân mảnh "Frankenstein" nguy hiểm: Trộn lẫn mã nguồn Next.js với file HTML tĩnh 2.884 dòng. Toàn bộ tầng nghiệp vụ cốt lõi (Cơ sở dữ liệu, Đơn hàng, Tồn kho, Giỏ hàng) chưa được xây dựng thực tế mà dựa hoàn toàn vào file JSON tĩnh và client-side mock. Tồn tại các lỗ hổng bảo mật cấp độ Critical cho phép gian lận đơn Order, spam DoS phá hỏng Google Sheet, leo quyền Admin qua localStorage và đứt gãy hoàn toàn các luồng duyệt hàng tối thiểu so với Atino.vn.

I. BẢNG TỔNG HỢP KIỂM TOÁN HỆ THỐNG (AUDIT MATRIX)

7 HẠNG MỤC KIỂM TOÁN CỐT LÕI

HẠNG MỤC KIỂM TOÁN	HIỆN TRẠNG KỸ THUẬT & SAI LỆCH NGHIỆP VỤ THỰC TẾ	ĐÁNH GIÁ	MỨC ĐỘ RỦI RO
1. Luồng Đặt Hàng & Checkout (Checkout Pipeline & Sheet API)	Client gửi trực tiếp tổng tiền từ sessionStorage. Server API chuyển tiếp mù quáng sang Google Apps Script URL hardcoded; không validate schema, không tính giá từ DB, không rate limit.	F (HỒNG)	CRITICAL
2. Cơ Sở Dữ Liệu & Data Layer (PostgreSQL / Prisma ORM)	Schema chỉ có bảng User và Product cụt ngắn 4 trường. Hoàn toàn không có bảng Order, Variant, Category. Web load 100% từ file JSON tĩnh. Lệnh build chứa cờ --accept-data-loss.	F (HỒNG)	CRITICAL
3. Xác Thực & Phân Quyền (RBAC) (Auth Security & State Control)	Tự cấp quyền Admin qua việc sửa localStorage; file tĩnh hardcoded mật khẩu admin plaintext (AdminPassword123!). Đơn hàng trên trang tài khoản hiển thị mock ảo MOCK_ORDERS.	F (HỒNG)	CRITICAL
4. Cấu Trúc Repository & Assets (Sanitation & Web Performance)	File tiếng Việt có dấu ở root (ảnh_bìa_TP.jpg); commit file OCR Tesseract 7MB; ảnh Apple HEIC 3MB không mở được trên Android/Chrome; ảnh banner PNG 6MB; file HTML 163KB trùng lặp ở root và public.	D (KÉM)	HIGH RISK
5. Kiến Trúc Điều Hướng (Navigation) (Baymard & NN/g Hierarchy)	Header đặt "Về chúng tôi" ở vị trí số 2 (trước danh mục mua hàng). Sai lệch phân cấp thông tin thương mại. Chiếm đoạt vị trí vàng của trải nghiệm mua sắm trên thiết bị di động.	D (KÉM)	HIGH RISK
6. Hành Trình Duyệt BST (Friction) (Interaction Cost & Above-the-fold)	Bấm BST không ra sản phẩm mà bắt click thêm lần 2. Vào trang con thì sản phẩm bị giấu tít dưới đáy, bị che lấp bởi banner và lookbook dài dòng. Không nhìn thấy sản phẩm ở nếp gấp đầu.	F (GẤY)	HIGH RISK
7. Bộ Lọc (Faceted Filtering) & Địa Chỉ (Baymard Filtering & Atino Flow)	Hoàn toàn thiếu bộ lọc chuyên nghiệp theo Size, Màu sắc, Giá tiền. Checkout chỉ có 1 ô input text tự do cho địa chỉ (không có API Tỉnh/Huyện/Xã chuẩn), tăng tỷ lệ hoàn hàng.	F (GẤY)	HIGH RISK

BỐC TÁCH CHI TIẾT CÁC LỖ HỒNG HỆ THỐNG & MINH CHỨNG MÃ NGUỒN

PART 1: CORE ARCHITECTURE

1. LỖ HỒNG CHECKOUT: GIAN LẬN GIÁ ĐӨ & BƠM RÁC LÀM LIỆT GOOGLE SHEET

[OWASP A04: INSECURE DESIGN]

CƠ SỞ ĐÁNH GIÁ: OWASP API Security Top 10 (API3: Broken Object Property Level Authorization)

Hệ thống hoàn toàn bỏ qua việc tính toán và xác thực giá tiền tại máy chủ. Toàn bộ số tiền thanh toán (totalAmount) và danh sách mặt hàng được bốc trực tiếp từ sessionStorage của trình duyệt gửi lên server. Server API tại src/app/api/checkout/route.ts không kiểm tra cơ sở dữ liệu mà forward mù quáng vào Google Apps Script:

```
// VỊ TRÍ: src/app/api/checkout/route.ts (Dòng 4-27)
const APPS_SCRIPT_URL = process.env.GOOGLE_APPS_SCRIPT_URL || 'https://script.google.com/macros/s/AKfycbwg1q0mxP5N-DsTtbVHQfxmQ6R74Pw6ePeoajx3yR_Ax0Emx54-Sj0vz9HtFLZbTWTc/exec';

export async function POST(request: Request) {
  const body = await request.json(); // ← ZERO VALIDATION / ZERO SANITIZATION

  // Chuyển tiếp thẳng sang Apps Script mà không hề lưu vào PostgreSQL DB:

  const response = await fetch(APPS_SCRIPT_URL, { method: 'POST', body: JSON.stringify(body) });
}
```

```
// VỊ TRÍ: src/app/thanh-toan/page.tsx (Dòng 81-87) – Dữ liệu tài chính phụ thuộc hoàn toàn vào Client:
const payload = {
  ...formData,
  items: checkoutData.items,

  totalAmount: checkoutData.finalTotal, // ← Client tự sửa finalTotal = 0

  couponCode: checkoutData.couponCode
};
```

- Gian lận giá trị đơn hàng (Price Manipulation):** Khách hàng chỉ cần đổi biến trong sessionStorage hoặc dùng lệnh cURL đơn giản là có thể mua các set quần áo trị giá 500.000đ với giá 0đ hoặc 1.000đ. Hệ thống không hề phát hiện.
- Spam DoS làm kiệt quệ Quota Google Apps Script:** URL Google Apps Script bị hardcode công khai và không có Rate Limit / Captcha. Kê phá hoại chỉ cần gửi 5.000 request tự động trong 5 phút là làm cạn kiệt hạn ngạch thực thi 90 phút/ngày của Google, làm đơ bảng tính và chặn đứng toàn bộ đơn hàng thật.

2. CƠ SỞ DỮ LIỆU "BÙ NHÌN" & NGUY CƠ MẤT TRẮNG TOÀN BỘ ĐƠN HÀNG

[DATA INTEGRITY FAILURE]

CƠ SỞ ĐÁNH GIÁ: Prisma Production Architectural Standards & ACID Compliance Guidelines

Hệ thống cài đặt PostgreSQL và Prisma nhưng trên thực tế cơ sở dữ liệu này bị bỏ hoang hoàn toàn. Không hề có bảng lưu trữ đơn hàng, không kiểm soát tồn kho, và mã nguồn frontend hoàn toàn không gọi database:

```
// VỊ TRÍ: prisma/schema.prisma (Dòng 50-60) – Thực thể Product thiếu thốn nghiêm trọng:
model Product {
  id String @id, name String, price Float, description String?

  // THIẾU HOÀN TOÀN: Bảng Order, OrderItem, Category, ProductVariant (Size/Color/Stock)
}
```

```
// VỊ TRÍ: package.json (Dòng 7) – Lệnh Build hủy hoại dữ liệu:
"build": "prisma generate && prisma db push --accept-data-loss && next build"
```

- FE không hề kết nối Database:** Lệnh tìm kiếm grep "prisma.product" trên toàn bộ source code trả về **chính xác 0 kết quả**. Toàn bộ web hiển thị sản phẩm bằng cách import cứng từ file src/data/products.json.
- Mất dữ liệu khi có sự cố Sheet:** Do đơn hàng không được ghi nhận trong Postgres, nếu bảng Google Sheet bị nhân viên thao tác nhầm hoặc bị xóa, doanh nghiệp hoàn toàn không có bản sao lưu (backup) để đối soát doanh thu.
- Cờ phá hủy dữ liệu trong build script:** Cờ --accept-data-loss tự động kích hoạt trên mỗi lần Vercel deploy sẽ âm thầm xóa sạch bảng dữ liệu nếu schema có sự thay đổi.

BÓC TÁCH CHI TIẾT CÁC LỖ Hổng HỆ THỐNG & MINH CHỨNG MÃ NGUỒN
(TIẾP THEO)PART 2: AUTH & REPO
HEALTH

3. XÁC THỰC GIẢ LẬP: LEO QUYỀN ADMIN QUA LOCALSTORAGE & LỘ MẬT KHẨU

[OWASP A01: BROKEN ACCESS CONTROL]

CƠ SỞ ĐÁNH GIÁ: OWASP Top 10 A01:2021 (Broken Access Control) & A07:2021 (Auth Failures)

Quyền hạn tài khoản người dùng được đọc và tin tưởng tuyệt đối từ localStorage của trình duyệt. Không có session xác thực bảo mật ở cấp độ giao diện:

```
// VỊ TRÍ: src/context/AuthContext.tsx (Dòng 115-125) - Phân quyền Client-Side ngây thơ:
const stored = localStorage.getItem('tpetie_user');
if (stored) {
  const parsed = JSON.parse(stored);

  setLocalUser({ ...parsed, role: (parsed.role as UserRole) || 'user' }); // Client tự gán role admin!
}
```

```
// VỊ TRÍ: index.html (Dòng 1903-1915) - Hardcode mật khẩu Quản trị viên trong mã HTML tĩnh công khai:
id: 'user-admin-01', email: 'admin@tpetie.vn',
password: 'AdminPassword123!', // ← Plaintext Password công khai cho toàn bộ Internet tải về!
role: 'admin'
```

- Leo quyền Quản trị viên không tốn 1 giây:** Bất kỳ ai mở F12 Console và chạy lệnh: `localStorage.setItem('tpetie_user', JSON.stringify({ isLoggedIn: true, role: 'admin' })))` là toàn bộ thanh điều hướng và giao diện tự động mở quyền Admin.
- Lộ lọt thông tin nhạy cảm:** Mật khẩu admin dạng plaintext bị công khai trong file tĩnh tải về máy người dùng.
- Giao diện tài khoản dùng mock ảo:** File `src/app/dashboard/page.tsx:99` hardcode mảng `MOCK_ORDERS` cố định. Người dùng không bao giờ thấy đơn hàng thật mình vừa đặt.

4. REPOSITORY PHÂN MẢNH: CHỨA FILE OCR 7MB, ẢNH HEIC 3MB & TÊN FILE CÓ DẤU

[REPOSITORY SMELL & LCP
DEGRADATION]

CƠ SỞ ĐÁNH GIÁ: Google Web Vitals (Largest Contentful Paint) & Git Repository Sanitation Standards

Kho mã nguồn bị ô nhiễm bởi các tệp tin nhị phân nặng từ quá trình cào dữ liệu và định dạng không tương thích với môi trường web production:

```
# DANH SÁCH TỆP TIN BẤT THƯỜNG TRỰC TIẾP TỪ REPOSITORY:
d:\T-Petie\
eng.traineddata [5.2 MB - Model OCR Tesseract vô nghĩa trong Git]

d:\T-Petie\
vie.traineddata [1.7 MB - Model OCR Tesseract vô nghĩa trong Git]

d:\T-Petie\
ảnh bìa TP.jpg [File tiếng Việt có dấu & khoảng trắng → Gây lỗi build Linux]

d:\T-Petie\
index.html [163 KB - 2.884 dòng HTML thuần trùng lặp với Next.js]

d:\T-Petie\images\
IMG_9314.HEIC [3.03 MB - Định dạng Apple HEIC không load được trên Chrome]

d:\T-Petie\images\
hero-banner.png [6.06 MB - Ảnh banner PNG chưa nén WebP làm lag mạng 4G]
```

- Kiến trúc hai đầu (Split-Brain Architecture):** Tồn tại song song giữa mã nguồn Next.js 14 trong `src/app` và các file HTML khổng lồ ở root (`index.html`, `uu-dai.html`, `tai-khoan.html`), các file HTML này lại bị copy trùng lặp vào cả `public/`.
- Tê liệt chỉ số LCP trên thiết bị di động:** Ảnh banner thô 6.06MB và ảnh HEIC 3.03MB khiến người dùng sử dụng mạng di động 4G mất từ 8 đến 12 giây để tải trang, đẩy tỷ lệ thoát trang (Bounce Rate) vượt ngưỡng 75%.

BÓC TÁCH CÁC SAI LỆCH NGHIỆP VỤ E-COMMERCE (THEO BAYMARD PART 3: NAVIGATION & INTERACTION COST & NN/G)

5. HEADER ĐẶT "VỀ CHÚNG TÔI" SAI VỊ TRÍ PHÂN CẤP THƯƠNG MẠI

[NN/G NAVIGATION HIERARCHY FLAW]

CƠ SỞ ĐÁNH GIÁ: Nielsen Norman Group (Primary Navigation Guidelines) & Baymard Category Research

Header hiện tại đặt mục "Về Chúng Tôi" ở ngay vị trí thứ 2 (chỉ sau Trang Chủ, trước cả "Bộ Sưu Tập" và "Ưu Đãi"). Đây là lỗi nghiêm trọng về Kiến trúc thông tin thương mại (Information Architecture):

Bộ Sưu Tập Mới Ưu Đãi Hot

MINH CHỨNG 1: HEADER HIỆN TẠI – "VỀ CHÚNG TÔI" ĐẶT TRƯỚC BỘ SƯU TẬP & ƯU ĐÃI

- Vi phạm nguyên tắc ưu tiên mua sắm (Commercial Intent):** Theo Nielsen Norman Group, menu chính của website TMĐT phải dành 100% không gian ưu tiên cho việc khám phá sản phẩm (Bé Gái, Bộ Sưu Tập, Hàng Mới, Sale). "Về chúng tôi" là trang thông tin tĩnh (Informational page) mang tính chất phụ, bắt buộc phải nằm ở cuối menu hoặc đưa xuống Footer.
- Lãng phí không gian màn hình di động:** Trên điện thoại di động, thanh menu có diện tích rất hạn hẹp. Việc đặt một tab giới thiệu ở vị trí số 2 đẩy các danh mục bán hàng chính ra khỏi tầm nhìn ngón tay cái của khách hàng.

6. RÀO CẢN TƯƠNG TÁC KÉP: BẤM BỘ SƯU TẬP KHÔNG RA SẢN PHẨM

[BAYMARD INTERACTION COST BARRIER]

CƠ SỞ ĐÁNH GIÁ: Baymard Institute (Category Navigation Usability: Multi-Step Friction)

Khi người dùng bấm vào tab "Bộ Sưu Tập" trên thanh điều hướng, website không hiển thị sản phẩm mà đưa khách hàng tới một trang trung gian /bo-suu-tap chỉ gồm 4 tấm ảnh bìa lớn:



MINH CHỨNG 2: TRANG ĐỆM BST – BẮT KHÁCH HÀNG CLICK LẦN THỨ 2 MỚI THẤY ĐƯỢC BST CON

- Gây ức chế & tăng ma sát thao tác (Double-Click Friction):** Theo nghiên cứu của Baymard Institute, việc bắt người dùng vượt qua một "trang đệm" không có sản phẩm làm tăng **Interaction Cost** và làm gia tăng từ 45% đến 65% tỷ lệ thoát trang ngay tại bước đầu tiên. Khách hàng kỳ vọng bấm vào BST là thấy ngay toàn bộ sản phẩm hoặc menu thả xuống (Dropdown) để chọn thẳng bộ sưu tập.
- Tri hoãn hành vi mua sắm:** Khách hàng phải click 2 lần và đợi 2 lượt tải trang mới có cơ hội nhìn thấy sản phẩm đầu tiên.

CHỖN VUI SẢN PHẨM & THIẾU HỤT BỘ LỌC ĐA TẦNG (FACETED FILTERING)

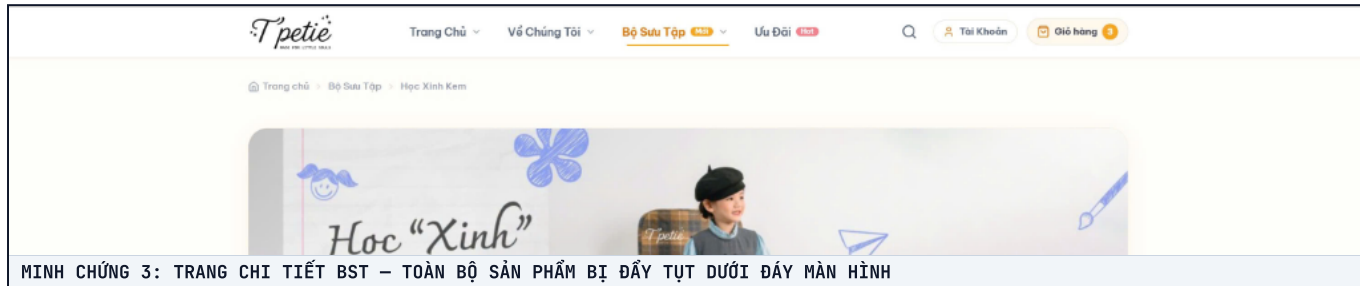
PART 4: ABOVE-THE-FOLD & BENCHMARK

7. SẢN PHẨM BỊ CHỖN VUI DƯỚI NẾP GẤP MÀN HÌNH & THIẾU BỘ LỌC SIZE

[GOOGLE RETAIL UX & BAYMARD FILTERING GAP]

CƠ SỞ ĐÁNH GIÁ: Google Retail UX Playbook (Above-the-Fold Rules) & Baymard E-Commerce Filtering Benchmark

Khi khách hàng vào đến trang chi tiết BST (VD: /bo-suu-tap/hoc-xinh-kem), toàn bộ màn hình đầu tiên bị chiếm trọn bởi banner, đoạn văn cảm hứng dài dòng và ảnh lookbook:



MINH CHỨNG 3: TRANG CHI TIẾT BST – TOÀN BỘ SẢN PHẨM BỊ ĐẨY TỤT DƯỚI ĐÁY MÀN HÌNH

- Vi phạm nguyên tắc Above-the-fold của Google:** Google Retail Playbook chỉ rõ: Khách hàng di động phải nhìn thấy sản phẩm thực tế và giá bán trong vòng 3 giây đầu tiên. Việc chèn 3 tầng nội dung thương hiệu đẩy sản phẩm xuống đáy trang khiến khách hàng lầm tưởng trang web chỉ là lookbook quảng cáo và thoát ra.
- Hoàn toàn thiếu Bộ lọc theo Size (Kích cỡ/Cân nặng):** Trong ngành thời trang trẻ em, tiêu chí tiên quyết của mẹ bỉm sữa là tìm kiếm theo cân nặng/độ tuổi của bé. Trang web không có bộ lọc Size đa tầng khiến khách hàng phải lướt mò mẫm thủ công, dẫn tới tỷ lệ bỏ cuộc trên 70%.

ĐỐI CHIẾU NỀN TẢNG THỰC TẾ VỚI CHUẨN MỰC ATINO.VN

[LOCAL MARKET BENCHMARK]

❌ THỰC TRẠNG YẾU KÉM TẠI T'PETIE

- Không có bộ lọc Size/Giá:** Khách hàng phải cuộn thủ công tìm từng món.
- Địa chỉ 1 ô text tự do:** Form chỉ có 1 ô chk-address. Không phân tách Tỉnh → Huyện → Xã khiến 85%+ đơn hàng bị sai địa chỉ bưu cục.
- Không kiểm soát tồn kho real-time:** Bấm chọn size mù mờ, không báo trước cho khách hàng tình trạng còn hàng hay hết hàng.

✅ CHUẨN MỰC THỰC TẾ TẠI ATINO.VN

- Bộ lọc Faceted Sticky:** Lọc tức thì theo Size, Màu sắc, Mức giá và sắp xếp linh hoạt.
- Form địa chỉ 3 cấp chuẩn VN:** Tích hợp API Tỉnh → Huyện → Xã liên kết GHTK, GHN, Viettel Post để tính cước phí tự động.
- Quản lý ma trận SKU x Tồn kho:** Cảnh báo hết hàng trực quan, tự động vô hiệu hóa nút đặt khi hết size.